

Plantilla de Excel – Cálculo de IGM y ROI con marco GQM + PRAGMATIC

Este documento describe cómo implementar una hoja de cálculo para:

- Calcular el Índice Global de Madurez (IGM) y subíndices basados en los indicadores M1–M15.
- Incorporar puntuaciones PRAGMATIC para selección/priorización de métricas.
- Estimar de forma aproximada el ROI de seguridad.

1. Estructura recomendada del libro

Se recomiendan, como mínimo, las siguientes hojas:

1. Respuestas – Datos codificados de la encuesta/medición (valores de M1–M15 por organización o sector).
2. Codificacion_Metricas – Tablas de codificación de respuestas a valores normalizados 0–100.
3. GQM_Metricas – Metadatos de cada métrica (meta GQM, preguntas, fórmula, fuente, frecuencia).
4. PRAGMATIC – Puntuaciones de cada métrica en los nueve criterios PRAGMATIC.
5. IGM – Cálculo de subíndices y del Índice Global de Madurez.
6. ROI – Cálculo del ROI de seguridad a partir de variaciones en el IGM y en el perfil de riesgo.
7. Parametros – Ponderaciones, umbrales, costes y otras constantes.

2. Hoja Respuestas

2.1. Columnas básicas

- Columna A: ID_Entidad (código anonimizado de organización o sector).
- Columna B: Sector (código o texto).
- Columna C: Tamano (categoría tamaño).
- Columnas D–R: valores numéricos para M1–M15 normalizados a 0–100.

Ejemplo de cabeceras:

- M1_Densidad_OWASP
- M2_Activos_sin_A01_A03
- M3_Cobertura_Top10
- ...
- M15_Tiempo_Deteccion_Decision

Nota: la normalización (0–100) se puede hacer directamente aquí o mediante referencias a Codificacion_Metricas.

2.2. Captura de datos

- Para métricas cualitativas (por ejemplo, rangos de porcentaje o niveles SAMM), se recomienda almacenar el valor numérico normalizado, dejando el texto en Codificacion_Metricas.
- Para métricas cuantitativas “puras” (por ejemplo, días de MTTR), se recomienda normalizar en función de rangos definidos en Parametros.

3. Hoja Codificacion_Metricas

3.1. Estructura

Por cada métrica Mx que se derive de una pregunta categórica, definir una tabla con:

ID_Metrica	Opcion_texto	Valor_bruto	Valor_0_100
M3	0-25 % apps críticas analizadas	1	25
M3	26-50 %	2	50
M3	51-75 %	3	75
M3	76-100 %	4	100

3.2. Uso de funciones

En Respuestas, las celdas pueden utilizar funciones como BUSCARV/VLOOKUP para traducir código u opción textual a valor 0-100.

Ejemplo (pseudocódigo en celda Respuestas!D2):

```
=BUSCARV(Codigo_respuesta;Codificacion_Metricas!$A$2:$D$100;4;FALSO)
```

4. Hoja GQM_Metricas

4.1. Metadatos por métrica

Tabla ejemplo:

ID_Metrica	Meta_GQM	Preguntas_GQM	Definicion_formal	Unidad	Fuente_datos	Frecuencia
M1	Cuantificar exposición estructural a vulnerabilidades OWASP Top 10.	Q1.1, Q1.2, Q1.3	Vulnerabilidades OWASP Top 10 por 100 activos.	vulns/100 activos	INCIBE/CCN + inventarios	Anual
M2	Evaluar robustez de activos críticos frente a A01-A03.	Q2.1, Q2.2, Q2.3	% activos críticos sin vulns A01-A03 altas/críticas.	%	Gestor de vulns + CMDB	Trimestral

4.2. Uso

Esta hoja no se usa directamente en cálculos, pero sirve para documentación, auditoría interna y formación.

5. Hoja PRAGMATIC

5.1. Tabla de puntuaciones

ID_Métrica	P_Pre dictivo	R_Rele vante	A_Acci onable	G_Gen uino	M_Sig nificati vo	A_Pre ciso	T_Opo rtuno	I_Inde p	C_Ren table	Nota_ global
M1	4	5	4	4	5	3	3	3	3	=PRO MEDIO(B2:J2)
M2	5	5	5	4	5	3	3	3	3	=PRO MEDIO(B3:J3)
...	...	...	...	...	...	...	...	...	...	...

5.2. Uso en selección de métricas

- La columna Nota_global permite ordenar las métricas por “calidad PRAGMATIC”.
- En Parametros se puede definir un umbral (por ejemplo, $\geq 3,5$) para elegir métricas “core” para el IGM.

6. Hoja IGM

6.1. Subíndices

Se recomienda definir cuatro subíndices:

- IGM_Exposicion – basado en M1–M4 (Top 10).
- IGM_SAMM – basado en M5–M8.
- IGM_ASVS – basado en M9–M12.
- IGM_Gob_Cultura – basado en M2 (vista gobernanza), M4, M5–M8, M13–M15 (según diseño).

Ejemplo de columnas:

| ID_Entidad | IGM_Exposicion | IGM_SAMM | IGM_ASVS | IGM_Gob_Cultura | IGM_Global |

6.2. Fórmulas de cálculo

Supongamos que, para una entidad en fila 2 de IGM, se referencian los valores 0–100 de M1–M15 en Respuestas.

Ejemplo para IGM_Exposicion (M1–M4):

=PROMEDIO(Respuestas!D2:Respuestas!G2)

Subíndices restantes seguirían la misma lógica, con los rangos correspondientes.

6.3. IGM global

En IGM_Global (columna F), dos opciones:

- Media simple:

=PROMEDIO(B2:E2)

- Media ponderada (usando pesos definidos en Parametros!B2:E2):

=SUMAPRODUCTO(B2:E2;Parametros!B2:E2)/SUMA(Parametros!B2:E2)

7. Hoja ROI

7.1. Estructura

| ID_Entidad | IGM_T0 | IGM_T1 | Delta_IGM | Riesgo_T0 | Riesgo_T1 | Riesgo_Evitado | Coste_Seguridad |
ROI |

- IGM_T0 / IGM_T1: valores del IGM en dos momentos (antes/después o año N/N+1).
- Riesgo_T0 / Riesgo_T1: estimación de riesgo económico (por ejemplo, valor esperado de pérdidas por ciberincidentes).
- Coste_Seguridad: costes incurridos en seguridad en el periodo.

7.2. Fórmulas

- Delta_IGM:

=IGM_T1-IGM_T0

- Riesgo_Evitado:

=Riesgo_T0-Riesgo_T1

- ROI:

=SI(Coste_Seguridad>0;(Riesgo_Evitado-Coste_Seguridad)/Coste_Seguridad;"")

Nota: el modelo para estimar Riesgo_T0/T1 depende de cada organización (por ejemplo, número esperado de incidentes × impacto medio). La plantilla solo proporciona la estructura.

8. Hoja Parametros

8.1. Ponderaciones de subíndices

Subíndice	Peso
IGM_Exposicion	0,25
IGM_SAMM	0,25
IGM_ASVS	0,25
IGM_Gob_Cultura	0,25

8.2. Umbrales de interpretación del IGM

- 0–24 – Crítico.
- 25–49 – Bajo.
- 50–74 – Medio.
- 75–100 – Alto.

8.3. Umbral de calidad PRAGMATIC

- PRAGMATIC_min_core = 3,5 (por ejemplo).
Métricas con nota global inferior pueden considerarse candidatas a “segunda línea” o revisarse.

9. Visualizaciones sugeridas

- Gráficos de barras y radar para subíndices IGM por entidad/sector.
- Mapas de calor para puntuaciones PRAGMATIC por métrica.
- Líneas de tendencia de IGM y riesgo estimado por entidad.

Esta plantilla ofrece un esqueleto suficientemente detallado para que un equipo de riesgos o analítica pueda convertir los resultados de la encuesta en un sistema vivo de métricas OWASP–NIS2 sensato, trazable y algo menos propenso a la poesía numérica sin fundamento.